Threat Analysis Report

รายงานวิเคราะห์แคมเปญ Phishing และแอปพลิเคชัน PEA Smart Plus ปลอม

24/10/2025

TLP:CLEAR

สำนักงานคณะกรรมการการรักษาความมั่นคงปลอดภัยไซเบอร์แห่งชาติ
๑๒๐ ชั้น ๗ อาคารซี ศูนย์ราชการเฉลิมพระเกียรติ ๘๐ พรรษา ๕ ธันวาคม ๒๕๕๐
ถนนแจ้งวัฒนะ แขวงทุ่งสองห้อง เขตหลักสี่ กรุงเทพมหานคร ๑๐๒๑๐ อีเมล saraban@ncsa.or.th

สารบัญ

สารบัญ 2
บทสรุปสำหรับผู้บริหาร 3
การวิเคราะห์เชิงเทคนิค 4
Technique Tactics and Procedures (MITRE ATT&CK) 13
Indicator of Compromise (IOCs) 14
แนวทางการเฝ้าระวัง ป้องกัน และรับมือ 16
อ้างอิง (References) 17

บทสรุปสำหรับผู้บริหาร

รายงานฉบับนี้วิเคราะห์แคมเปญการหลอกหลวงและล่อลวงให้ทำการติดตั้งแอปพลิเคชัน PEA Smart Pro ซึ่งเป็นแอปพลิเคชันปลอม โดยลอกเลียนแบบแอปพลิเคชัน PEA Smart Plus ของการไฟฟ้าส่วนภูมิภาค

จากการตรวจสอบไฟล์ Android Package (APK) ที่ถูกพบว่าถูกโฮสต์อยู่บนเว็บไซต์ปลอม (phishing website) ซึ่งมีลักษณะเลียนแบบเว็บไซต์จริง พบว่ามีความเป็นไปได้สูงว่าเป็นมัลแวร์ประเภท Remote Access Trojan (RAT) หรือ Banking Trojan ที่มุ่งเน้นการเข้าถึงและขโมยข้อมูลส่วนบุคคลของผู้ใช้งาน

จากการวิเคราะห์เชิงเทคนิค พบว่าแอปพลิเคชันร้องขอสิทธิ์เข้าถึงข้อมูลและความสามารถระดับสูงหลายรายการ เช่น การอ่าน SMS, รายชื่อผู้ติดต่อ, และสถานะโทรศัพท์ การเข้าถึงไมโครโฟน กล้อง การเริ่มต้นการทำงานด้วยตนเอง และการบังหน้าจอ ซึ่งสิทธิ์เหล่านี้เกินความจำเป็นของแอปทั่วไป และสามารถถูกนำมาใช้ควบคุมอุปกรณ์จากระยะไกล หรือสอดแนมข้อมูลผู้ใช้ได้

นอกจากนี้ยังตรวจพบลักษณะของการ obfuscation และการเข้ารหัสไฟล์ภายใน (resources และ native libraries) ซึ่งบ่งชี้ถึงความพยายามในการซ่อนพฤติกรรมหรือข้อมูลการติดต่อกับเซิร์ฟเวอร์ควบคุม (Command and Control Server) โดยแม้ไม่พบ URL ของ C2 โดยตรง แต่จากรูปแบบสิทธิ์และโครงสร้างของโค้ด มีแนวโน้มว่าแอปอาจมีการ ส่งข้อมูลออกผ่านช่องทาง HTTPS ไปยัง C2 เพื่อการสื่อสารและสั่งการ

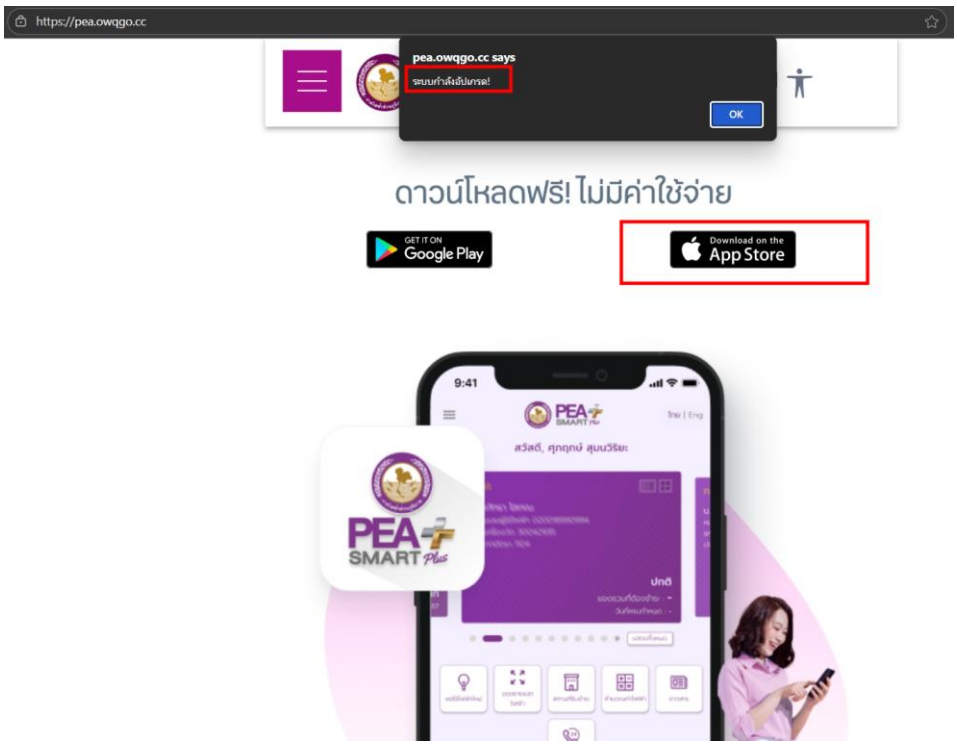
การวิเคราะห์เชิงเทคนิค

Phishing Website

การวิเคราะห์เริ่มต้นที่ขึ้น URL https://pea.owqgo[.]cc/ ซึ่งเป็นเว็บไซต์ลอกเลียนแบบมาจากเว็บไซต์จริงของการไฟฟ้าส่วนภูมิภาคที่ใช้ในการลิงค์ไปสู่ App store และ Play Store สำหรับดาวน์โหลดแอปพลิเคชัน PEA Smart Plus (https://www.pea.co.th/our-services/mobile-apps) แต่จุดที่แตกต่างกันคือ เว็บไซต์ลอกเลียนแบบเน้นรองรับการใช้งานผ่าน Web Browser บนอุปกรณ์มือถือมากกว่า และเมนูที่ผู้ใช้สามารถที่เรียกใช้ได้จริงนั้นจะมีเพียงแค่การดาวน์โหลดเท่านั้น

[ภาพเว็บ Phishing]

เมนูดาวน์โหลดของเว็บไซต์ปลอมนั้นจะมีเมนูสำหรับระบบปฏิบัติการ Android และ IOS แต่ในด้านของ IOS นั้นเมื่อเลือกเว็บไซต์จะแจ้งเตือนว่า “ระบบกำลังอัปเกรด” แสดงให้เห็นว่าผู้ไม่หวังดีมีกลุ่มเป้าหมายเป็นผู้ใช้งานระบบปฏิบัติการ Android



[ภาพเว็บการเลือกดาวน์โหลดสำหรับระบบปฏิบัติการ IOS]

จากการตรวจสอบเพิ่มเติมของผู้วิเคราะห์ผ่าน WhereGoes พบว่าในส่วนของ HTTP header, การวิเคราะห์ซอร์สโค้ด และ การวิเคราะห์ข้อมูลเครือข่าย มีรายละเอียดดังนี้

HTTP Headers:

- **Server:** Cloudflare: ผู้ไม่หวังดีใช้ Cloudflare เป็น Proxy เพื่อ ซ่อน IP Address ที่แท้จริงของเซิร์ฟเวอร์ (Origin IP) ทำให้การสืบหาต้นตอทำได้ยากขึ้น
- **cache-control:** no-store: เพื่อสั่งไม่ให้ Browser หรือ Proxy ทำการ Cache หน้าเว็บนี้ไว้ เพื่อให้เหยื่อได้รับโค้ดที่เป็นอันตรายชุดล่าสุดเสมอ
- **x-robots-tag:** noindex, nofollow: เป็นคำสั่งบอก Search Engines (เช่น Google) ว่า "ห้ามเก็บข้อมูล (index) และห้ามไต่ลิงก์ (follow) จากหน้านี้" ซึ่งเป็นพฤติกรรมของหน้า Phishing ที่ไม่ต้องการให้ใครหาเจอ ยกเว้นเหยื่อที่ได้รับลิงก์โดยตรง

WHEREGOES
FROM CLICK TO LOAD

1 200 https://pea.owqgo.cc/

Response Body:

```
HTTP/2 200
date: Fri, 24 Oct 2025 02:13:01 GMT
content-type: text/html; charset=UTF-8
server: cloudflare
nel: {"report_to":"cf-nel","success_fraction":0.0,"max_age":604800}
access-control-allow-headers: token,rangex
access-control-allow-methods: POST,GET,OPTIONS,DELETE
cache-control: no-store
referrer-policy: no-referrer
strict-transport-security: max-age=0; includeSubDomains
```

Response MetaData:

```
Host: pea.owqgo.cc
user-agent: Wheregoes.com Redirect Checker/1.0
accept: */*
accept-encoding: gzip
accept-language: en-US,en;q=0.5

    [effective_method] => GET
)
```

Trace Complete - 1

[ภาพการวิเคราะห์ลิงค์]

การวิเคราะห์ซอร์สโค้ด:

Two-Stage Payload Delivery:

- ลิงก์ (https://pea.owqgo.cc/) ทำหน้าที่เป็นเปลือกโดย JavaScript ขนาดเล็กฝังอยู่
- JavaScript นี้จะทำการ fetch หรือร้องขอข้อมูลจาก URL ที่สองคือ https://pea.owqgo.cc/x/page เพื่อดึง "เนื้อหาจริง" เข้ามา

Obfuscation & Evasion Technique (เทคนิคการซ่อนโค้ดและหลบเลี่ยง):

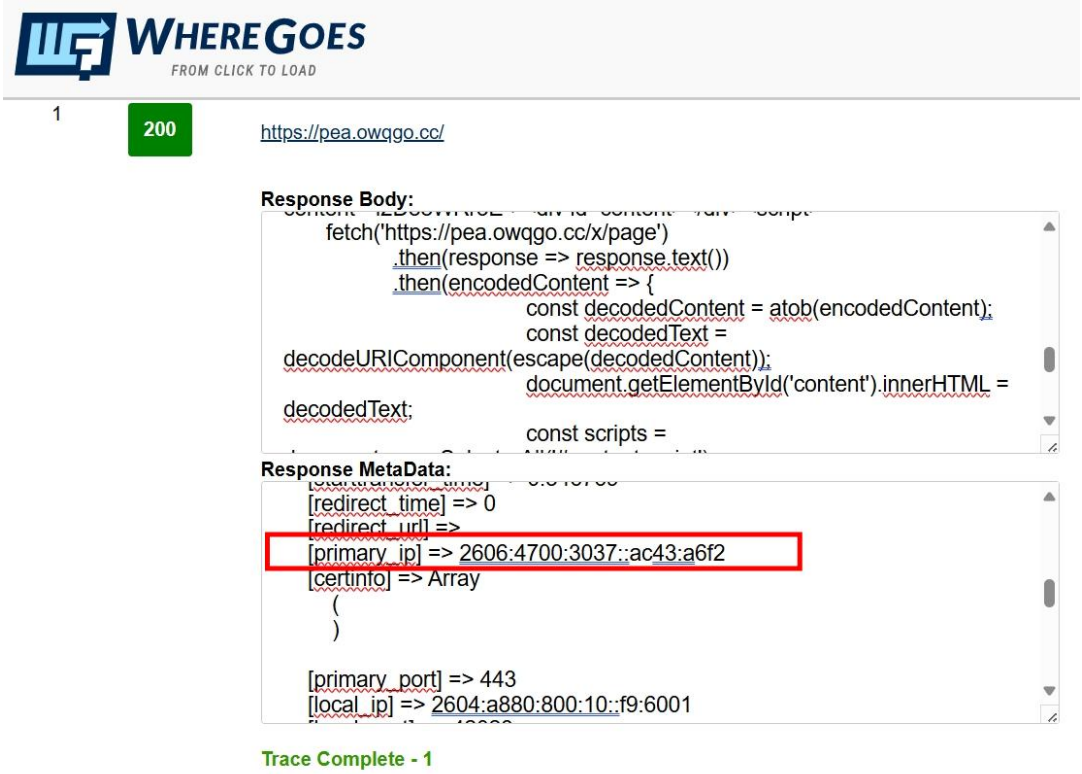
- **response.text():** รับเนื้อหาจริงมาในรูปแบบข้อความ (Text) ซึ่งคาดว่าจะเป็น Base64 String
- **const decodedContent = atob(encodedContent);:** ใช้ฟังก์ชัน atob() เพื่อ ถอดรหัส Base64 กลับมาเป็นโค้ด HTML/JavaScript ต้นฉบับ นี่เป็นเทคนิคพื้นฐานในการซ่อนโค้ดจากโปรแกรม Antivirus หรือ URL scanner แบบง่ายๆ

- **document.getElementById('content').innerHTML = decodedText;:** นำโค้ดที่ถอดรหัสแล้ว ฉีด (inject) เข้าไปในหน้าเว็บเพื่อให้แสดงผลเป็นหน้า Phishing ที่สมบูรณ์
- **Dynamic Script Execution: ส่วนที่วน loop scripts.forEach** เป็นเทคนิคเพื่อให้แน่ใจว่าถ้าโค้ดที่ถอดรหัสมามี <script> tag อยู่ด้วย มันจะถูกรันอย่างแน่นอน ซึ่งเป็นการยืนยันว่า Payload ที่สองนั้นมีความซับซ้อนและอาจมีสคริปต์สำหรับขโมยข้อมูลอยู่ด้วย

[ภาพเทคนิคการซ่อนโค้ดและหลบเลี่ยง]

การวิเคราะห์ข้อมูลเครือข่าย (Network/Infrastructure Analysis)

- **primary_ip: 2606:4700:3037::ac43:a6f2:** เป็น IPv6 Address ของ Cloudflare ซึ่งยืนยันข้อมูลจาก HTTP Header ว่าผู้โจมตีซ่อนอยู่หลัง CDN

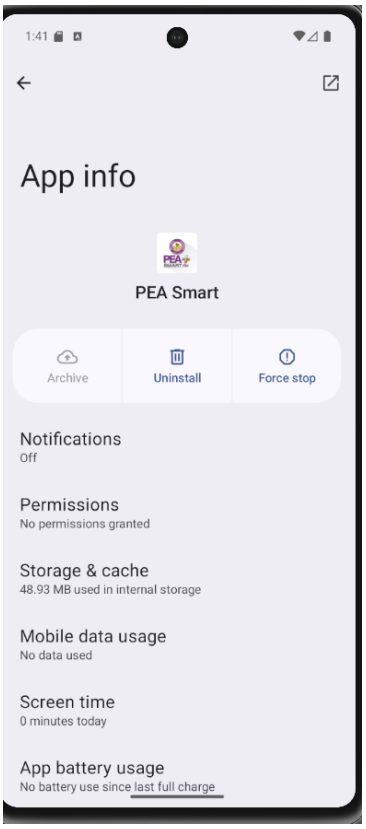


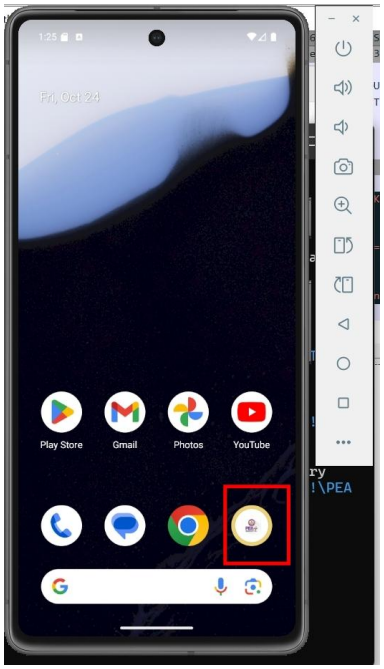
[ภาพ primary IP ที่ผู้ไม่หวังดีใช้หลอกให้เหยื่อดาวน์โหลดไฟล์]

Fake PEA Smart Plus Application (APK)

ผลการทดลองติดตั้งลงบนสภาพแวดล้อมเสมือน (Virtual Android)

เนื่องจากแอปพลิเคชันที่เป็นอันตรายนั้นรองรับการติดตั้งและใช้งานบนระบบสถาปัตยกรรมแบบ ARM64 จึงไม่สามารถทำการทดสอบการทำงานได้





[ภาพการทดลองติดตั้งแอปพลิเคชันที่เป็นอันตราย]

ผลการทดสอบด้วยเครื่องมือ MobSF

จากการวิเคราะห์ด้วยเครื่องมือ MobSF ได้ข้อมูลที่สำคัญมาคือการขอ Permission ต่าง ๆ ของตัวแอปพลิเคชัน โดยมีการขอ Permission ดังนี้

android.permission.READ_SMS
android.permission.BIND_ACCESSIBILITY_SERVICE
android.permission.RECORD_AUDIO
android.permission.REQUEST_DELETE_PACKAGES
android.permission.QUERY_ALL_PACKAGES
android.permission.GET_INSTALLED_APPS
android.permission.WRITE_EXTERNAL_STORAGE
android.permission.READ_EXTERNAL_STORAGE
android.permission.READ_PRIVILEGED_PHONE_STATE
android.permission.DISABLE_KEYGUARD
android.permission.WAKE_LOCK
android.permission.REQUEST_IGNORE_BATTERY_OPTIMIZATIONS
android.permission.RECEIVE_BOOT_COMPLETED
android.permission.SYSTEM_ALERT_WINDOW
android.permission.FOREGROUND_SERVICE
android.permission.ACCESS_NETWORK_STATE
android.permission.ACCESS_WIFI_STATE
android.permission.USE_FULL_SCREEN_INTENT
android.permission.INTERNET
android.permission.BATTERY_STATS
android.permission.REORDER_TASKS
android.permission.ACCESS_COARSE_LOCATION
android.permission.ACCESS_FINE_LOCATION
android.permission.ACCESS_BACKGROUND_LOCATION
android.permission.CAMERA
android.permission.READ_CONTACTS
android.permission.SCHEDULE_EXACT_ALARM
android.permission.SYSTEM_OVERLAY_WINDOW
android.permission.USE_EXACT_ALARM
android.permission.FOREGROUND_SERVICE_DATA_SYNC
android.permission.MOUNT_UNMOUNT_FILESYSTEMS
android.permission.MANAGE_EXTERNAL_STORAGE
app.krjmo.ujiky.backtrace.warmed_up
app.krjmo.ujiky.manual.dump
app.krjmo.ujiky.matrix.permission.PROCESS_SUPERVISOR
android.permission.READ_PHONE_STATE

จาก Permission ข้างต้นจะพบว่ามีหลายการร้องขอที่อันตรายโดยแบ่งเป็นหมวดหมู่ได้ดังนี้

กลุ่ม Permission สำหรับการอ่านข้อมูลต่าง ๆ

Permission	คำอธิบาย
READ_SMS	อ่านข้อความ SMS ทั้งหมด รวมถึงรหัส OTP จากธนาคารหรือระบบยืนยันตัวตน
READ_CONTACTS	ดูรายชื่อ / เบอร์โทรในเครื่อง ซึ่งสามารถใช้ส่งต่อฟิชชิ่ง หรือขยายการแพร่กระจาย
READ_PHONE_STATE, READ_PRIVILEGED_PHONE_STATE	เข้าถึง IMEI, หมายเลขโทรศัพท์, สถานะซิม, และข้อมูลเครือข่าย ใช้ระบุ device ID
GET_INSTALLED_APPS, QUERY_ALL_PACKAGES	รู้ว่าเครื่องติดตั้งแอปอะไรบ้าง เพื่อเจาะ targeting เช่น ธนาคาร หรือ crypto app
MANAGE_EXTERNAL_STORAGE, READ/WRITE_EXTERNAL_STORAGE, MOUNT_UNMOUNT_FILESYSTEMS	เข้าถึงและอ่าน/เขียนไฟล์ทั้งหมดในเครื่องได้ แม้แต่ไฟล์ที่ไม่ควรแตะ (เช่น รูป, เอกสาร, log)

กลุ่ม Permission สำหรับการควบคุมเครื่อง / ทำงานอัตโนมัติ

Permission	คำอธิบาย
BIND_ACCESSIBILITY_SERVICE	ใช้ควบคุมหน้าจอ, คลิกปุ่ม, อ่านข้อมูลหน้าจอ, bypass 2FA, และควบคุมแอปอื่น ๆ
SYSTEM_ALERT_WINDOW, SYSTEM_OVERLAY_WINDOW	แสดง overlay ทับหน้าจอ เช่น หน้าปลอมของธนาคารเพื่อหลอกให้ผู้ใช้กรอกข้อมูล
DISABLE_KEYGUARD, WAKE_LOCK	ปลุกหน้าจอหรือปลดล็อกอัตโนมัติได้
REORDER_TASKS	สลับ foreground app เพื่อหลอกตาผู้ใช้ เช่น เปิดหน้าจอปลอมทับแอปจริง
REQUEST_DELETE_PACKAGES	ลบแอปอื่นออกจากเครื่อง (รวมถึง antivirus)
RECEIVE_BOOT_COMPLETED	เริ่มทำงานอัตโนมัติเมื่อเปิดเครื่อง
FOREGROUND_SERVICE, FOREGROUND_SERVICE_DATA_SYNC	รันใน background โดยไม่ถูกระบบ kill ได้ง่าย

กลุ่ม Permission สำหรับสอดแนม / บันทึกเสียง / ตำแหน่ง

Permission	คำอธิบาย
RECORD_AUDIO	อัดเสียงหรือสนทนา
CAMERA	ถ่ายรูป/วิดีโอโดยไม่แจ้งเตือน
ACCESS_FINE_LOCATION, ACCESS_COARSE_LOCATION, ACCESS_BACKGROUND_LOCATION	ติดตามตำแหน่ง GPS แบบเรียลไทม์

กลุ่ม Permission ที่ถูกสร้างขึ้นมาเป็นพิเศษ

Permission	คำอธิบาย
app.krjmo.ujiky.backtrace.warmed_up app.krjmo.ujiky.manual.dump app.krjmo.ujiky.matrix.permission. PROCESS_SUPERVISOR	เป็น custom permission ภายในแอป

Technique Tactics and Procedures (MITRE ATT&CK)

MITRE ATT&CK คือฐานความรู้ที่รวบรวมและจัดหมวดหมู่กลยุทธ์และเทคนิคต่างๆ ที่ผู้ไม่หวังดีใช้ในการโจมตีทางไซเบอร์ โดยอ้างอิงจากเหตุการณ์ที่เกิดขึ้นจริง เพื่อให้ฝ่ายป้องกันสามารถเข้าใจและรับมือกับภัยคุกคามได้ดียิ่งขึ้น

Tactic	Technique ID	Technique Name
Initial Access	T1476	Deliver Malicious App via Web or App Store
	T1475	Deliver Malicious App via Social Engineering
Execution	T1623	Abuse Accessibility Features
	T1648	Abuse Android Intent Permissions
Persistence	T1547.001	Boot or Logon AutoStart Execution: Boot Completed
	T1401	Device Administrator Permissions
Defense Evasion	T1628	Obfuscated Files or Information
Credential Access	T1412	Capture SMS Messages
Collection	T1402	Audio Capture
	T1513	Camera Capture
	T1517	Application Discovery
	T1530	Data from Local System
	T1629	File and Directory Discovery
Command and Control	T1430	Application Layer Protocol
Exfiltration	T1409	Exfiltration Over C2 Channel
Impact	T1471	Data Encryption for Impact

Indicator of Compromise (IOCs)

Indicators of Compromise (IOCs) คือ ร่องรอยหรือหลักฐานทางดิจิทัลที่บ่งชี้ว่าระบบหรือเครือข่ายอาจถูกบุกรุกโดยผู้ไม่หวังดี ซึ่งทาง สกมช. ได้มีการแบ่งปันข้อมูล IOCs เหล่านี้ผ่านทางแพลตฟอร์ม MISP (Malware Information Sharing Platform) เพื่อเสริมสร้างความมั่นคงปลอดภัยไซเบอร์เรียบร้อยแล้ว โดยมีร่องรอยที่สามารถตรวจสอบได้ดังนี้

ร่องรอยที่สามารถตรวจสอบได้:

URL (Phishing)

https://pea.owqgo[.]cc/

8.219.85.91:8888/push-streaming?id=1234

101.37.81.24/test

203.107.1.1/d?host=

Domain (Phishing)

owqgo.cc

IP Address

101.37.81.24

8.219.85.91

203.107.1.1

IP:PORT

8.219.85.91:8888

Filename

PEA SMART PRO.apk

MD5

a0d2e2a98fab8a337df36e5e299c72c6

SHA1

fdf853202389e0e1fb0546bd973f329acc179886

SHA256

a7e99157f8828d07d394822d5aa0eb806640d8ac6b678792ab9cd2d6faa4be

Other

rtmp://101.37.81.24/test

ws://8.219.85.91:8888/push-streaming?id=1234

แนวทางการเฝ้าระวัง ป้องกัน และรับมือ

การเฝ้าระวัง (Monitoring)

- ตรวจสอบการเชื่อมต่อเครือข่าย: เฝ้าตรวจสอบการเชื่อมต่อที่ผิดปกติ โดยเฉพาะการส่งข้อมูลออกผ่าน HTTPS ไปยังโดเมนที่ไม่ทราบที่มา
- ตรวจสอบแหล่งที่มาของแอปพลิเคชันก่อนดาวน์โหลด: ตรวจสอบแหล่งที่มาของแอปพลิเคชันว่ามีความน่าเชื่อถือหรือไม่ เป็นเว็บไซต์ทางการหรือได้รับการยืนยันหรือไม่
- ตรวจสอบการขอสิทธิ์ต่าง ๆ ที่มากเกินความจำเป็น: ตรวจสอบการร้องขอสิทธิ์ของแอปพลิเคชันว่ามีความสมเหตุสมผลกับลักษณะและจุดประสงค์ของการใช้งานหรือไม่

การป้องกัน (Prevention)

- ควบคุมช่องทางการติดตั้งแอป: หากไม่มีความจำเป็นควรจำกัดการติดตั้งแอปเฉพาะจาก Google Play Store หรือแหล่งที่ได้รับการอนุมัติจากองค์กรเท่านั้น
- เพิ่มความปลอดภัยของอุปกรณ์มือถือ: เปิดใช้งาน Google Play Protect หรือระบบตรวจจับมัลแวร์ใน MDM, จำกัดสิทธิ์ของแอปในการเข้าถึงข้อมูลส่วนบุคคล เช่น SMS, รายชื่อผู้ติดต่อ, กล้อง และตำแหน่ง
- การให้ความรู้แก่ผู้ใช้งาน: จัดอบรมให้พนักงานตระหนักถึงความเสี่ยงจากการดาวน์โหลดแอปพลิเคชันจากลิงก์ในอีเมลหรือเว็บไซต์ที่ไม่น่าเชื่อถือ

การรับมือ (Response)

- แยกอุปกรณ์ที่ติดเชื้อ: ให้ตัดการเชื่อมต่อเพื่อหยุดการสื่อสารระหว่างเครื่องที่ติดเชื้อกับผู้ไม่หวังดีในระยะเบื้องต้น
- เก็บหลักฐานทางดิจิทัล: รักษาสภาพของเครื่องที่ติดเชื้อไว้เพื่อการวิเคราะห์หาสาเหตุและสืบสวน (Digital Forensics)
- กู้คืนระบบ: ถอนการติดตั้งแอปพลิเคชันต้องสงสัย และตรวจสอบว่ามีการติดตั้ง payload อื่นหรือไม่, เปลี่ยนรหัสผ่านของบัญชีผู้ใช้ทั้งหมดที่อาจถูกเข้าถึงจากอุปกรณ์นั้น
- รายงานเหตุการณ์: แจ้งเหตุการณ์ไปยังหน่วยงานที่เกี่ยวข้องภายในองค์กรและหน่วยงานด้านความมั่นคงปลอดภัยไซเบอร์

อ้างอิง (References)

1. NSCA's Digital Forensic and Incident Response Team
2. NCSA's Cyber Threat Intelligence Team
3. MITRE ATT&CK®

แบบประเมินรายงานข่าวกรองไซเบอร์

https://dg.th/nsexlfob51

จัดทำโดย

ฤทธิ์นภา ประเสริฐศรี

ฝ่ายบริหารจัดการข้อมูลภัยคุกคามทางไซเบอร์ สำนักประสานงาน
ศูนย์ประสานการรักษาความมั่นคงปลอดภัยระบบคอมพิวเตอร์แห่งชาติ
โทร: 02 114 3531 อีเมล: cti_misp@ncsa.or.th